

单位代码： 10293 密 级： \_\_\_\_\_

南京邮电大学  
专业学位论文



论文题目： 基于 agent 的自动 web 漏洞挖掘

|        |            |
|--------|------------|
| 学 号    | 1025040906 |
| 姓 名    | 韩俊杰        |
| 导 师    | 沙乐天        |
| 专业学位类别 | 计算机        |
| 类 型    | 学硕         |
| 专业（领域） | 网络安全       |
| 论文提交日期 | 2026/6/11  |

# 摘要

随着互联网技术高速发展，Web 应用已成为当下数字化服务的核心载体，广泛应用于政务、金融、民生等多个关键领域。但由于 Web 系统开发门槛低、业务迭代速度快、开发人员安全意识参差不齐等问题，SQL 注入、跨站脚本、文件上传、权限越权等高危漏洞层出不穷。各类 Web 安全漏洞极易引发数据泄露、服务器沦陷、恶意代码植入等网络安全事件，给企业运营与用户信息安全造成巨大威胁。传统 Web 漏洞挖掘方式分为人工渗透测试与自动化扫描工具检测两类，人工检测精度高但效率低下、人力成本高昂，无法适配海量 Web 站点检测场景；传统自动化扫描工具规则固化、智能化程度不足，面对复杂动态网页、加密接口以及变形攻击载荷的识别能力较差，存在漏报率、误报率偏高的痛点，难以满足现阶段复杂网络环境下自动化、智能化漏洞挖掘的业务需求。针对上述现存问题，本文引入智能 Agent 技术，设计并实现一套基于多智能 Agent 的自动化 Web 漏洞挖掘方案。方案依托大语言模型驱动智能 Agent，拆分导航 Agent、探测 Agent、攻击 Agent 与决策分析 Agent 四大功能模块，各司其职完成网页自主遍历、接口动态探测、漏洞载荷自适应生成、漏洞验证与结果研判全流程工作。导航 Agent 能够自主解析动态网页 DOM 结构，模拟真实用户行为完成页面跳转、表单提交等操作；探测 Agent 通过爬虫技术抓取 Web 接口与路由信息，完成目标资产梳理；攻击 Agent 结合漏洞特征库与智能生成算法，针对不同漏洞类型自适应优化攻击载荷；决策分析 Agent 汇总检测数据，判别漏洞有效性并剔除无效误报数据。同时本文优化 Agent 决策机制，引入记忆反馈机制，让 Agent 能够根据历史检测经验迭代优化检测策略，提升复杂场景下的适配能力。本文研究成果可为 Web 应用安全检测提供全新的智能化解决思路，弥补传统漏洞扫描技术智能化不足的短板，适配中小型企业、网络安全运维人员的日常安全检测需求。最后结合实验现状，分析当前方案存在的局限性，并对多 Agent 协同挖掘、轻量化模型部署等后续优化方向进行展望。

**关键词：** Web 漏洞挖掘；智能 Agent；多智能体协同；动态爬虫；渗透测试

# Abstract

With the rapid development of Internet technology, Web applications have become the core carrier of current digital services and are widely used in many key fields such as government affairs, finance and people's livelihood. However, due to the low development threshold of Web systems, rapid business iteration, and uneven security awareness of developers, high-risk vulnerabilities such as SQL injection, cross-site scripting, file upload and unauthorized access emerge in an endless stream. Various Web security vulnerabilities easily trigger network security incidents including data leakage, server compromise and malicious code implantation, posing huge threats to enterprise operation and user information security. Traditional Web vulnerability mining methods are divided into manual penetration testing and automated scanning tool detection. Manual detection has high accuracy but low efficiency and high labor cost, which cannot adapt to the detection scenarios of massive Web sites. Traditional automated scanning tools have fixed rules and insufficient intelligence, and perform poorly in identifying complex dynamic web pages, encrypted interfaces and deformed attack payloads, accompanied by high false negative and false positive rates, which cannot meet the requirements of intelligent automated vulnerability mining under the current complex network environment. To solve the above problems, this paper introduces intelligent Agent technology and designs an automated Web vulnerability mining scheme based on multi-intelligent Agents. Driven by large language models, the scheme divides functional modules into navigation Agent, detection Agent, attack Agent and decision analysis Agent to complete the whole process including autonomous web page traversal, dynamic interface detection, adaptive payload generation, vulnerability verification and result evaluation. The navigation Agent can independently parse the DOM structure of dynamic web pages and simulate real user behaviors such as page jumping and form submission; the detection Agent captures Web interfaces and routing information through crawling technology to sort out target assets; the attack Agent generates and optimizes attack payloads adaptively for different types of vulnerabilities based on vulnerability feature database and intelligent generation algorithm; the decision analysis Agent summarizes detection data to identify effective vulnerabilities and eliminate invalid false alarm data. Meanwhile, the decision-making mechanism of Agent is optimized with a memory feedback module, enabling the Agent to iteratively optimize detection strategies based on historical detection experience and improve adaptability in complex scenarios. The research results of this paper provide a new intelligent solution for Web application security detection, make up for the shortcomings of insufficient intelligence of traditional vulnerability scanning technology, and meet the daily security detection needs of small and medium-sized enterprises and network security operation and

maintenance personnel. Finally, the limitations of the current scheme are analyzed combined with experimental results, and the future optimization directions such as multi-Agent collaborative mining and lightweight model deployment are prospected.

**Key Words:** Web Vulnerability Mining; Intelligent Agent; Multi-Agent Collaboration; Dynamic Crawler; Penetration Testing

# 目 录

|                                   |      |
|-----------------------------------|------|
| 摘要 .....                          | I    |
| Abstract .....                    | II   |
| 插图索引 .....                        | VI   |
| 表格索引 .....                        | VII  |
| 专用术语注释表 .....                     | VIII |
| <b>第一章 绪论</b> .....               | 1    |
| 1.1 研究背景 .....                    | 1    |
| 1.2 研究意义 .....                    | 2    |
| 1.2.1 理论意义 .....                  | 2    |
| 1.2.2 现实意义 .....                  | 2    |
| 1.3 国内外研究现状 .....                 | 2    |
| <b>第二章 相关技术基础</b> .....           | 4    |
| 2.1 Web 应用基础架构 .....              | 4    |
| 2.2 主流 Web 漏洞分析 .....             | 4    |
| 2.2.1 SQL 注入漏洞 .....              | 5    |
| 2.2.2 跨站脚本漏洞 (XSS) .....          | 5    |
| 2.3 本章小结 .....                    | 5    |
| <b>第三章 系统总体方案设计</b> .....         | 6    |
| 3.1 系统设计目标 .....                  | 6    |
| 3.1.1 功能性需求 .....                 | 6    |
| 3.1.2 任务调度层 .....                 | 7    |
| 3.2 多 Agent 功能模块详细设计 .....        | 7    |
| 3.3 本章小结 .....                    | 8    |
| <b>第四章 系统详细设计与实现</b> .....        | 9    |
| 4.1 开发环境与整体技术架构 .....             | 9    |
| 4.1.1 开发环境 .....                  | 9    |
| 4.1.2 核心技术栈 .....                 | 9    |
| 4.2 公共基础模块实现 .....                | 10   |
| 4.2.1 会话管理模块 .....                | 10   |
| 4.2.2 洞特征库构建 .....                | 10   |
| 4.3 本章小结 .....                    | 10   |
| <b>第五章 探测 Agent 详细设计与实现</b> ..... | 12   |
| 5.1 攻击 Agent 详细设计与实现 .....        | 12   |
| 5.1.1 多维并行混合 .....                | 12   |
| 5.1.2 异常熔断机制 .....                | 12   |
| 5.2 接口清洗与分类实现 .....               | 13   |
| 5.2.1 会话管理模块 .....                | 13   |
| 5.2.2 模块功能架构 .....                | 13   |
| 5.3 硬件环境 .....                    | 13   |
| 5.4 本章小结 .....                    | 14   |

|                   |    |
|-------------------|----|
| 第六章 总结与展望 .....   | 15 |
| 6.1 本文工作总结 .....  | 15 |
| 6.2 进一步研究方向 ..... | 15 |
| 参考文献 .....        | 17 |
| 附录 A 程序清单 .....   | 19 |

# 插图索引

# 表格索引



专用术语注释表

符号说明：

| 符号    | 表示含义 |
|-------|------|
| $B_D$ | 多普勒扩 |

缩略词说明：

| 缩写 | 英文全称      |
|----|-----------|
| 5G | 5th Gener |

# 第一章 绪论

## 1.1 研究背景

在数字化时代全面普及的当下，B/S 架构的 Web 应用凭借开发便捷、跨平台适配、运维成本低廉等多项优势，已经成为各行各业信息化建设的核心载体。从政务公开系统、线上金融平台、电子商务网站，到日常社交软件、办公管理系统，Web 应用深度融入社会生产与大众生活的方方面面。根据 CNNIC 发布的互联网发展统计报告显示，国内 Web 应用数量常年保持千万级别增长，中小型 Web 站点占比超过 75%。Web 应用依托 HTTP/HTTPS 协议完成数据交互，开放化的访问模式在赋予用户便捷服务的同时，也使其长期暴露在复杂的网络攻击环境之中。现阶段多数中小型 Web 应用开发团队以业务功能实现为核心目标，普遍存在开发流程不规范、代码审计缺失、安全测试环节简化等问题。同时业务高频迭代的行业特性，进一步加剧安全隐患，SQL 注入、跨站脚本攻击、垂直水平越权、恶意文件上传、不安全反序列化等常见高危漏洞频发。一旦漏洞被攻击者利用，极易引发用户隐私数据泄露、后台服务器权限沦陷、网站页面被篡改、业务系统瘫痪等恶性网络安全事件。从国家层面来看，《网络安全法》《数据安全法》等相关法律法规陆续落地实施，明确要求企事业单位落实网络安全主体责任，定期完成业务系统漏洞检测与风险整改；从行业层面而言，各类网络安全攻防赛事、公开漏洞平台披露的 Web 漏洞数量逐年攀升，攻击者的攻击手段逐渐趋向智能化、复合化、隐蔽化，传统单一的防护手段已经无法抵御新型攻击方式。在此行业大环境下，常态化、智能化的 Web 漏洞挖掘工作，成为网络安全防护体系中不可或缺的核心环节。现阶段 Web 漏洞挖掘主要分为人工渗透测试与自动化漏洞扫描两种模式。人工渗透测试依托渗透工程师的专业经验，能够深度挖掘复合型、隐藏型漏洞，检测精度较高，但是该模式作业效率极低、人力成本高昂，无法适配海量 Web 站点的批量检测场景，仅适用于核心重要系统的专项安全测评。传统自动化漏洞扫描工具凭借程序化检测逻辑，能够批量完成资产探测与漏洞检测，作业效率远超人工测试，现已成为中小型企业安全运维的主流工具。但此类工具存在底层缺陷，检测规则依赖专家人工编写，规则库更新存在滞后性，智能化自适应能力匮乏，针对动态渲染网页、加密接口、变形攻击载荷的识别能力较差，普遍存在漏报率高、误报冗余、无法自主探索未知漏洞等问题，难以适配当下复杂多变的 Web 应用环境。随着大语言模型、智能 Agent 等人工智能技术快速迭代，人工智能与网络安全的跨界融合成为行业研究新趋势。智能 Agent 具备自主决策、环境感知、行为迭代、记忆学习等特性，能够模拟人类渗透测试人员的思维与操作行为，自主完成网页遍历、接口探测、漏洞验证等系列操作，完美弥补传统扫描工具智能化不足的短板。基于此，本文结合智能 Agent 技术，研究并设计全自动化、高适配性的 Web 漏洞挖掘方案，解决传统漏洞挖掘模式存在的痛点问题。

## 1.2 研究意义

随着大语言模型、智能 Agent 等人工智能技术快速迭代，人工智能与网络安全的跨界融合成为行业研究新趋势。智能 Agent 具备自主决策、环境感知、行为迭代、记忆学习等特性，能够模拟人类渗透测试人员的思维与操作行为，自主完成网页遍历、接口探测、漏洞验证等系列操作，完美弥补传统扫描工具智能化不足的短板。基于此，本文结合智能 Agent 技术，研究并设计全自动化、高适配性的 Web 漏洞挖掘方案，解决传统漏洞挖掘模式存在的痛点问题。

### 1.2.1 理论意义

现阶段国内关于 Web 漏洞挖掘的研究大多集中于爬虫算法优化、漏洞特征匹配、载荷生成优化等单一模块，针对智能 Agent 赋能漏洞挖掘的系统性研究较少，且现有多 Agent 架构多应用于网络攻防博弈、简单端口探测等浅层场景，尚未形成标准化、可落地的 Web 全流程漏洞挖掘架构。本文基于多智能体协同思想，拆分导航、探测、攻击、决策四大功能 Agent，明确各模块的职责边界与协同交互逻辑，构建一套完整的智能化自动漏洞挖掘体系。同时引入记忆反馈机制优化 Agent 决策模型，完善智能 Agent 在复杂 Web 环境下的动态决策算法，丰富人工智能技术在 Web 渗透测试领域的应用理论体系，为后续智能化漏洞挖掘相关研究提供全新的研究思路与理论参考。

### 1.2.2 现实意义

本课题研究成果具备极强的落地应用价值。针对中小型企业安全团队人员短缺、安全预算有限、传统扫描工具检测效果差的行业痛点，本文设计的自动漏洞挖掘系统无需人工深度干预，能够自主完成资产探测、页面遍历、漏洞扫描、结果研判全流程工作，降低漏洞挖掘的技术门槛与人力成本。相较于 AWVS、Xray 等传统商用扫描工具，本系统适配静态网页、动态渲染网页、加密私有接口等多种应用场景，有效降低漏洞漏报率与误报率，提升隐藏型、复合型 Web 漏洞的挖掘能力。该方案不仅可以服务于企业日常安全运维、版本迭代安全测试工作，还能够为高校网络安全教学、攻防演练平台提供技术支撑，具备广泛的应用场景。

## 1.3 国内外研究现状

国外针对 Web 漏洞挖掘技术的研究起步较早，整体技术体系成熟，相关研究覆盖算法优化、工具研发、智能化升级多个维度。在传统漏洞挖掘技术层面，早在 2000 年左右，国外研究人员便提出基于模糊测试、静态代码分析、动态程序分析的三类主流漏洞检测技术，并研发出多款经典开源及商用扫描工具，例如开源工具 OWASP ZAP、Nikto，商用工具 AWVS、

Burp Suite 等，时至今日依旧是全球渗透测试人员的核心作业工具。在智能化漏洞挖掘研究领域，近年来国外科研机构深度结合大语言模型与 Agent 技术开展相关研究。Google 安全实验室提出基于单智能 Agent 的 Web 自动渗透框架，依托大模型实现网页元素识别与简单表单交互操作，能够自主完成基础的 SQL 注入、XSS 漏洞检测；MIT 计算机安全实验室创新性提出多 Agent 协同攻防模型，将渗透测试流程拆解为资产扫描、载荷攻击、漏洞验证、日志分析多个子任务，由不同功能 Agent 独立承接，实验证明多 Agent 架构在复杂 Web 系统漏洞挖掘中的表现优于单一智能模型。与此同时，OpenAI 团队发布的专用安全 Agent 模型，具备自主学习渗透测试知识、复盘检测失败案例的能力，可自主完成 OWASP Top10 全类型漏洞的挖掘工作。综合来看，国外智能化漏洞挖掘研究已经从单一模型检测，逐步转向多智能体协同作业，技术成熟度较高，但现有开源框架普遍存在部署成本高、模型体量庞大、适配国内本土化 Web 应用场景较差等问题，无法直接在国内中小型企业中普及落地。

## 第二章 相关技术基础

Web 应用采用经典的 B/S（浏览器/服务器）架构，整体架构分为客户端层、服务端层、数据层三个层级，各层级协同完成用户请求接收、业务逻辑处理、数据存储与响应的全流程工作。该架构模式解耦性强，客户端无需安装专用程序，仅依靠浏览器即可完成访问，是目前互联网应用最主流的架构模式。

### 2.1 Web 应用基础架构

Web 应用采用经典的 B/S（浏览器/服务器）架构，整体架构分为客户端层、服务端层、数据层三个层级，各层级协同完成用户请求接收、业务逻辑处理、数据存储与响应的全流程工作。该架构模式解耦性强，客户端无需安装专用程序，仅依靠浏览器即可完成访问，是目前互联网应用最主流的架构模式。客户端层主要为用户浏览器，负责发送 HTTP/HTTPS 请求、解析服务端返回的 HTML、JS、CSS 等资源，完成页面渲染与人机交互。随着前端技术迭代，Vue、React 等框架被广泛应用，动态渲染网页占比逐年提升，前端页面不再依赖静态 HTML 文件，而是通过 AJAX 异步请求获取后端接口数据，再由 JS 脚本完成页面动态渲染，大幅提升用户交互体验，但同时也增加了漏洞挖掘页面遍历的难度。服务端层是 Web 应用的核心业务载体，由 Web 服务器与业务程序组成。常见 Web 服务器包含 Nginx、Apache、Tomcat 等，主要负责请求转发、负载均衡、权限基础校验；业务程序依托 Java、Python、PHP、Go 等编程语言开发，承接用户登录、数据查询、文件上传、权限分配等核心业务逻辑，同时直接与数据层进行数据交互，是漏洞高发的核心区域。数据层主要由 MySQL、Oracle、Redis 等关系型与非关系型数据库组成，负责存储 Web 应用的用户信息、业务数据、权限配置数据等核心资源。数据层为业务程序提供数据读写支撑，一旦出现 SQL 注入等漏洞，攻击者可直接非法读取、篡改数据库内部数据，造成严重的安全事故。

### 2.2 主流 Web 漏洞分析

OWASP（开放式 Web 应用安全项目）定期发布 Top10 高危 Web 漏洞清单，该清单总结全球范围内出现频率最高、危害程度最大的 Web 安全漏洞，是漏洞挖掘与安全防护工作的重要参考标准。本文结合课题研究场景，选取五类高频高危漏洞进行详细原理分析。

### 2.2.1 SQL 注入漏洞

SQL 注入是出现频率最高、危害性极强的基础高危漏洞。该漏洞产生的核心原因是 Web 后端程序未对用户输入参数做过滤、转义与合法性校验，直接将用户可控参数拼接至 SQL 语句中执行。攻击者通过构造特殊的恶意输入载荷，篡改原始 SQL 语句的执行逻辑，非法实现数据库数据查询、数据篡改、权限提升、服务器文件读取等操作。SQL 注入漏洞根据触发形式可分为布尔型注入、时间盲注、报错型注入；根据注入位置可分为 GET 请求注入、POST 请求注入、Cookie 注入。针对传统静态 Web 页面，规则匹配模式即可高效检测注入漏洞，但针对加密参数、动态接口的变形注入攻击，传统扫描工具检测效果较差，需要依托智能算法自适应生成多样化攻击载荷。

### 2.2.2 跨站脚本漏洞 (XSS)

跨站脚本漏洞简称 XSS 漏洞，成因是 Web 应用未对用户输入的脚本类数据进行过滤与编码，直接将恶意 JS 脚本渲染至前端页面并执行。攻击者利用该漏洞植入恶意脚本，可窃取用户 Cookie 信息、劫持用户会话、伪造用户操作、弹窗钓鱼，甚至控制用户浏览器。按照触发场景划分，XSS 漏洞主要分为存储型、反射型与 DOM 型三类。其中 DOM 型 XSS 依托前端 JS 代码触发，无需后端参与，普遍存在于动态渲染网页中，传统扫描爬虫无法精准识别 DOM 节点风险，漏报问题极为突出，也是本文系统重点优化检测的漏洞类型。

## 2.3 本章小结

模糊测试是一种自动化黑盒渗透测试技术，核心原理为向目标 Web 接口自动批量发送经过变异、随机化处理的畸形载荷，监测程序是否出现报错、超时、崩溃等异常现象，以此挖掘未知漏洞与隐性漏洞。相较于常规动态检测，模糊测试载荷随机性更强，能够突破固定规则库的限制，具备挖掘 0day 未知漏洞的潜力。然而传统模糊测试盲目性较高，冗余测试请求数量庞大，检测耗时久、资源占用量大；且变异载荷无针对性，无效请求占比极高，整体检测效率低下，难以直接应用于中小型 Web 站点的常态化安全扫描。静态应用安全测试简称静态检测技术，该技术无需运行 Web 应用程序，直接对项目源代码、二进制文件进行词法分析、语法分析、数据流分析与污点分析，结合预设漏洞规则库，匹配代码中存在的安全风险点。静态检测可覆盖 SQL 注入、代码后门、不安全配置、硬编码密钥等多种漏洞类型，能够在项目开发阶段提前发现安全隐患，从源头规避漏洞产生。静态检测技术优势在于检测速度快、能够定位漏洞代码位置、适配项目开发全流程；但其短板同样十分明显，该技术仅能检测代码层已知漏洞，无法识别业务逻辑类漏洞，且极易产生大量误报数据，需要安全人员人工逐一复核，无法独立完成完整的漏洞挖掘工作。

## 第三章 系统总体方案设计

结合前文对传统 Web 漏洞挖掘技术的短板分析以及智能 Agent 技术的应用优势，本文旨在设计一款基于多智能 Agent 的全自动、轻量化、高适配性 Web 漏洞挖掘系统。系统以黑盒检测模式为基础，无需依赖 Web 项目源代码，面向中小型 Web 应用实现全流程无人化漏洞检测，弥补传统扫描工具智能化不足、动态页面适配差、逻辑类漏洞漏报率高等缺陷。本系统具体设计目标分为以下四点：

### 3.1 系统设计目标

为保障系统架构规范性、运行稳定性与可拓展性，本文在系统整体设计阶段遵循模块化、高安全性、低耦合性、易用性四项基本原则，全方位规范系统开发逻辑：模块化设计原则。按照 Web 漏洞挖掘业务流程进行功能拆分，将系统整体划分为四大智能 Agent 模块、漏洞特征库模块、任务调度模块与数据存储模块。各模块功能边界清晰，独立完成对应子任务，便于单独调试、优化与功能替换，同时降低后期维护难度。低耦合高内聚原则。内部子模块仅通过统一数据接口完成信息交互，禁止跨模块直接调用底层函数与算法。模块内部聚焦单一业务功能，实现高内聚；模块间相互独立、互不干扰，实现低耦合，有效规避单一模块故障引发整体系统崩溃的问题。安全性设计原则。系统在漏洞挖掘过程中遵循渗透测试规范，设置请求频率阈值、最大并发数与高危操作拦截机制，避免高频畸形请求造成目标 Web 服务器卡死、业务瘫痪等破坏性问题；同时对采集的网站账号、接口参数、业务数据进行加密存储，杜绝敏感数据泄露。可拓展性原则。预留功能拓展接口，支持后续新增漏洞检测类型、接入新型 AI 模型、拓展爬虫交互功能、增加多语种识别能力；任务调度模块支持子 Agent 新增与删减，能够根据业务需求快速升级为多集群分布式检测架构。

#### 3.1.1 功能性需求

结合前文 2.5 章节多智能体协同技术研究内容，考虑 Web 漏洞挖掘流程具备线性化、步骤固定、层级清晰的特点，本文选用集中式多智能体架构完成系统搭建。整体架构自上而下分为四层，分别为任务调度层、智能 Agent 执行层、算法支撑层、数据持久层。四层架构相互配合、逐级支撑，共同完成智能化自动漏洞挖掘任务，规避分布式架构通信复杂、开发成本过高的弊端，兼顾检测性能与轻量化部署需求。任务调度层作为系统全局管控核心，承担中心决策者角色，负责整体任务拆解、子任务分配、Agent 状态监控、执行节奏调度与最终数据汇总；智能 Agent 执行层为系统作业主体，包含导航 Agent、探测 Agent、攻击 Agent、决策分析 Agent 四大功能子 Agent，各司其职完成导航遍历、资产探测、载荷攻击、漏洞研判子

任务；算法支撑层为 Agent 提供底层算法赋能，包含动态遍历算法、智能载荷生成算法、记忆反馈决策算法、漏洞判别算法；数据持久层负责所有业务数据、模型数据、特征数据的存储与读写，支撑系统全流程运行。

### 3.1.2 任务调度层

任务调度层。该层级是整个多 Agent 系统的大脑，接收用户下发的检测任务后，根据 Web 漏洞挖掘执行顺序，将总任务拆解为页面遍历、资产采集、漏洞扫描、结果分析四大子任务，并按照优先级依次下发至对应的执行 Agent。同时实时监听各 Agent 运行状态，及时处理任务超时、请求封禁、接口报错等异常问题，协调多 Agent 之间的数据交互，避免重复探测、任务抢占等冲突问题。智能 Agent 执行层。执行层直接面向目标 Web 应用，承接调度层下发的子任务，是漏洞挖掘工作的直接执行者。四大 Agent 相互独立且数据互通，执行层严格按照“导航—探测—攻击—研判”的作业链路协同工作，完成从环境感知到漏洞输出的全流程作业。各 Agent 详细功能设计将在 3.4 小节展开阐述。算法支撑层。该层级为执行层 Agent 提供底层算法支撑，是实现智能化作业的关键。动态遍历算法用于优化导航 Agent 的页面交互逻辑，提升动态元素识别能力；智能载荷生成算法服务于攻击 Agent，根据漏洞类型自动变异优化攻击载荷；记忆反馈决策算法为所有 Agent 提供迭代学习能力，复盘历史任务优化决策策略；漏洞判别算法辅助决策 Agent 精准区分真实漏洞与误报数据。

## 3.2 多 Agent 功能模块详细设计

导航 Agent 是系统执行检测任务的首个功能模块，核心定位为环境感知与页面交互，主要负责完成目标 Web 站点的初始化访问、动态页面遍历、用户身份维持、可交互元素采集，为后续探测 Agent 提供完整的页面访问环境。该模块解决传统爬虫无法适配动态渲染页面、无法模拟真人交互的行业痛点。导航 Agent 具体功能包含以下四个方面：第一，环境初始化，根据目标 URL 发起访问请求，配置请求头、超时时间、请求代理，自动处理 Cookie 会话、验证码弹窗、浏览器防盗链等基础访问问题；第二，账号登录模拟，针对权限受限后台系统，支持静态账号密码自动填充登录，维持长期有效会话；第三，动态页面遍历，基于内置动态遍历算法，识别按钮、输入框、下拉菜单、文件上传控件等可交互 DOM 元素，模拟真人点击、输入、刷新等行为，触发 AJAX 异步请求，抓取隐藏路由；第四，页面去重管理，剔除重复页面与 404 无效页面，将处理后的有效页面数据同步至探测 Agent。



### 3.3 本章小结

本章立足于前文相关技术基础,结合现有漏洞挖掘技术的痛点与不足,完成基于多 Agent 的自动 Web 漏洞挖掘系统整体方案设计。首先明确系统设计目标与四大设计原则,并从功能性与非功能性两个维度完成全方位需求分析;其次搭建四层集中式多智能体总体架构,逐层阐述层级定位与核心功能;随后对导航 Agent、探测 Agent、攻击 Agent、决策分析 Agent 四大核心模块进行精细化功能拆分;最后设计系统闭环运行流程与混合任务调度机制、标准化数据交互机制。本章所设计的总体方案,为下一章系统详细实现、算法优化与代码开发提供完整的架构依据与技术规范。

## 第四章 系统详细设计与实现

结合本系统轻量化、易部署的设计目标，同时兼顾开发便捷性与运行稳定性，本系统整体采用 Python 语言进行开发。Python 语言具备丰富的第三方爬虫库、网络请求库与大模型调用接口，能够快速完成页面交互、报文抓取、智能载荷生成、模型推理等相关功能，高度适配 Web 漏洞挖掘系统的开发需求。

### 4.1 开发环境与整体技术架构

为适配动态网页遍历、多 Agent 协同调度、智能化决策推理等核心业务，本系统采用分层化技术栈，涵盖网络请求、动态页面渲染、智能模型推理、多进程调度、数据存储五大模块。网络请求层面基于 Requests 库完成静态报文交互；动态页面层面采用 Selenium 结合 Chrome 无头浏览器，模拟真人用户操作，解决 SPA 单页应用异步渲染问题；模型推理层面接入轻量化开源大模型 Qwen-1.8B，本地离线部署，无需依赖云端接口；任务调度层面基于多进程异步队列实现串并行混合调度；数据存储层面采用 MySQL 存储结构化资产与漏洞数据，配套 JSON 文件存储攻击载荷与临时日志。

#### 4.1.1 开发环境

会话管理是保障多 Agent 协同检测、维持登录态一致性的基础公共模块。传统扫描工具多采用单次独立请求模式，无法维持长期有效的 Cookie 会话，针对权限受限的后台管理系统检测效果极差。本系统单独封装全局会话池，统一管理所有 Agent 的请求头、Cookie、代理参数，实现多模块会话数据共享。会话管理模块具备会话创建、会话复用、会话刷新、异常销毁四项功能。导航 Agent 完成账号登录操作后，将有效会话存入全局会话池；探测 Agent 与攻击 Agent 直接复用已有会话，无需重复登录；当会话过期、被服务器封禁时，模块自动触发重新登录机制，刷新会话信息；针对彻底失效的会话，自动销毁并记录异常日志，保障检测任务连续性。

#### 4.1.2 核心技术栈

漏洞特征库是攻击载荷生成与漏洞结果研判的数据基础，本文结合 OWASP Top10 高危漏洞标准，构建结构化本地漏洞特征库。特征库内部存储各类漏洞的漏洞简介、触发条件、高危参数、基础载荷集合、判别规则、修复建议六大维度数据，覆盖 SQL 注入、XSS、文件上传、权限越权、不安全反序列化五大核心漏洞类型。为提升载荷适配性，特征库按照请求方

式划分为 GET 型载荷、POST 型载荷、Cookie 型载荷，同时内置 WAF 绕过专用变异载荷子集。攻击 Agent 可根据接口属性精准匹配对应的载荷集合，有效减少无效测试请求；决策分析 Agent 可调用判别规则库，辅助完成多维度漏洞判定，降低误报率。

## 4.2 公共基础模块实现

记忆反馈机制是区别于传统扫描工具的核心创新点，该机制赋予智能 Agent 复盘学习、策略迭代的能力，解决传统自动化程序策略固化、无法适配多变 Web 环境的痛点。记忆反馈模块整体分为数据采集、特征提取、权重更新、策略同步四个子单元。数据采集单元负责采集单次检测任务内的正向数据与负向数据，正向数据包含成功触发漏洞的交互动作、攻击载荷、请求参数；负向数据包含误报请求、被 WAF 拦截载荷、无效页面交互行为。特征提取单元依托大模型对历史数据进行标签化分类，标注数据对应的应用场景与失败成因。权重更新单元基于梯度下降算法，调整 Agent 决策模型权重，增加高成功率行为的执行优先级，降低无效行为权重。策略同步单元将更新后的决策策略同步至四大 Agent，完成全局策略迭代。

### 4.2.1 会话管理模块

为解决单一抓取方式接口采集不全的问题，本系统采用三重抓取策略，从静态源码、动态请求、表单节点三个维度同步采集接口资产。静态层面正则匹配 HTML 源码内的 URL 链接、表单 Action 地址；动态层面解析浏览器 Network 日志，抓取异步请求产生的私有接口；表单层面解析所有 Form 表单参数、提交方式与提交地址，覆盖 POST、PUT、DELETE 等非常规请求接口。三重策略相互补充，全方位挖掘站点内全部潜在攻击接口。

### 4.2.2 洞特征库构建

为解决单一抓取方式接口采集不全的问题，本系统采用三重抓取策略，从静态源码、动态请求、表单节点三个维度同步采集接口资产。静态层面正则匹配 HTML 源码内的 URL 链接、表单 Action 地址；动态层面解析浏览器 Network 日志，抓取异步请求产生的私有接口；表单层面解析所有 Form 表单参数、提交方式与提交地址，覆盖 POST、PUT、DELETE 等非常规请求接口。三重策略相互补充，全方位挖掘站点内全部潜在攻击接口。

## 4.3 本章小结

为解决单一抓取方式接口采集不全的问题，本系统采用三重抓取策略，从静态源码、动态请求、表单节点三个维度同步采集接口资产。静态层面正则匹配 HTML 源码内的 URL 链

接、表单 Action 地址；动态层面解析浏览器 Network 日志，抓取异步请求产生的私有接口；表单层面解析所有 Form 表单参数、提交方式与提交地址，覆盖 POST、PUT、DELETE 等非常规请求接口。三重策略相互补充，全方位挖掘站点内全部潜在攻击接口

## 第五章 探测 Agent 详细设计与实现

接口清洗环节主要完成两类过滤操作：其一，过滤静态资源类接口，剔除图片、视频、CSS、JS、字体文件等无漏洞检测价值的资源路由；其二，基于 URL 归一化算法，剔除同源同参数的重复接口，规避重复检测造成的资源浪费。接口分类环节按照业务属性将接口划分为数据查询类、数据提交类、文件上传类、权限管理类四大类别，并结合漏洞特征库完成漏洞标签标注，例如为上传类接口绑定文件上传漏洞标签，为参数可控的查询接口绑定 SQL 注入、XSS 漏洞标签。

### 5.1 攻击 Agent 详细设计与实现

攻击 Agent 是漏洞挖掘的核心执行模块，主要由载荷匹配单元、智能生成单元、载荷变异单元、批量测试单元组成。载荷匹配单元根据接口标签筛选基础攻击载荷；智能生成单元依托轻量化大模型生成定制化测试载荷；载荷变异单元对原始载荷进行变形优化，绕过基础 WAF 防护；批量测试单元异步发送攻击请求，并完整记录请求与响应数据。

#### 5.1.1 多维并行混合

现阶段国内关于 Web 漏洞挖掘的研究大多集中于爬虫算法优化、漏洞特征匹配、载荷生成优化等单一模块，针对智能 Agent 赋能漏洞挖掘的系统性研究较少，且现有多 Agent 架构多应用于网络攻防博弈、简单端口探测等浅层场景，尚未形成标准化、可落地的 Web 全流程漏洞挖掘架构。本文基于多智能体协同思想，拆分导航、探测、攻击、决策四大功能 Agent，明确各模块的职责边界与协同交互逻辑，构建一套完整的智能化自动漏洞挖掘体系。同时引入记忆反馈机制优化 Agent 决策模型，完善智能 Agent 在复杂 Web 环境下的动态决策算法，丰富人工智能技术在 Web 渗透测试领域的应用理论体系，为后续智能化漏洞挖掘相关研究提供全新的研究思路与理论参考

#### 5.1.2 异常熔断机制

为解决传统扫描工具误报率过高的行业痛点，决策分析 Agent 摒弃单一响应码判别模式，构建多维综合漏洞判别模型，判别指标包含 HTTP 响应状态码、页面关键字回显、请求响应时间、数据库报错特征、权限访问差异性。模型为不同漏洞类型配置差异化权重系数，例如检测 SQL 注入优先参考数据库报错与响应时间；检测 XSS 优先参考页面脚本回显；检测越权漏洞优先参考多账号访问权限差异。多维度联动判别模式，能够显著降低漏洞误报率。

## 5.2 接口清洗与分类实现

为解决传统扫描工具误报率过高的行业痛点，决策分析 Agent 摒弃单一响应码判别模式，构建多维综合漏洞判别模型，判别指标包含 HTTP 响应状态码、页面关键字回显、请求响应时间、数据库报错特征、权限访问差异性。模型为不同漏洞类型配置差异化权重系数，例如检测 SQL 注入优先参考数据库报错与响应时间；检测 XSS 优先参考页面脚本回显；检测越权漏洞优先参考多账号访问权限差异。多维度联动判别模式，能够显著降低漏洞误报率。

### 5.2.1 会话管理模块

漏洞特征库是攻击载荷生成与漏洞结果研判的数据基础，本文结合 OWASP Top10 高危漏洞标准，构建结构化本地漏洞特征库。特征库内部存储各类漏洞的漏洞简介、触发条件、高危参数、基础载荷集合、判别规则、修复建议六大维度数据，覆盖 SQL 注入、XSS、文件上传、权限越权、不安全反序列化五大核心漏洞类型。为提升载荷适配性，特征库按照请求方式划分为 GET 型载荷、POST 型载荷、Cookie 型载荷，同时内置 WAF 绕过专用变异载荷子集。攻击 Agent 可根据接口属性精准匹配对应的载荷集合，有效减少无效测试请求；决策分析 Agent 可调用判别规则库，辅助完成多维度漏洞判定，降低误报率。

### 5.2.2 模块功能架构

导航 Agent 作为系统的前置感知模块，由浏览器驱动单元、交互行为单元、页面解析单元、页面去重单元四部分组成。浏览器驱动单元基于无头浏览器完成页面初始化访问；交互行为单元负责模拟真人用户操作；页面解析单元抓取 DOM 元素与异步路由；页面去重单元过滤冗余无效页面，输出标准化页面资源清单。

## 5.3 硬件环境

在智能化漏洞挖掘研究领域，近年来国外科研机构深度结合大语言模型与 Agent 技术开展相关研究。Google 安全实验室提出基于单智能 Agent 的 Web 自动渗透框架，依托大模型实现网页元素识别与简单表单交互操作，能够自主完成基础的 SQL 注入、XSS 漏洞检测；MIT 计算机安全实验室创新性提出多 Agent 协同攻防模型，将渗透测试流程拆解为资产扫描、载荷攻击、漏洞验证、日志分析多个子任务，由不同功能 Agent 独立承接，实验证明多 Agent 架构在复杂 Web 系统漏洞挖掘中的表现优于单一智能模型。与此同时，OpenAI 团队发布的专用安全 Agent 模型，具备自主学习渗透测试知识、复盘检测失败案例的能力，可自主完成 OWASP Top10 全类型漏洞的挖掘工作。

## 5.4 本章小结

结合 Web 漏洞挖掘行业通用评价标准，本文从功能性指标与性能指标两个维度制定评价体系。功能性指标用于判定系统是否具备完整的漏洞检测能力；性能指标用于量化对比不同扫描工具的综合检测水平，各项指标定义如下：（1）漏报率（False Negative Rate, FNR）：指代样本内真实存在但未被工具检测出的漏洞数量占总漏洞样本的比例。漏报率是衡量扫描工具综合检测能力的核心指标，漏报率越低，代表工具挖掘隐性漏洞、深层漏洞的能力越强。

（2）误报率（False Positive Rate, FPR）：指代工具检测出的无效告警、虚假漏洞数量占全部告警数量的比例。过高的误报率会增加人工复核成本，是传统扫描工具普遍存在的痛点问题。

（3）平均检测时长：完成单套待测 Web 应用全流程扫描所消耗的平均时间，用于评判工具的检测效率。

（4）场景适配率：统计工具在静态页面、动态 SPA 页面、权限管理系统、加密接口场景下的适配成功率，用于评判工具复杂环境兼容能力。

## 第六章 总结与展望

### 6.1 本文工作总结

随着 Web 前端技术快速迭代升级, SPA 单页应用、微服务架构逐步成为主流开发模式, 动态渲染页面、私有化加密接口、复合型业务逻辑漏洞占比逐年提升。传统 Web 漏洞扫描工具以静态爬虫与固定模糊测试规则为核心, 存在动态页面遍历残缺、逻辑类漏洞无法识别、误报率居高不下、适配场景单一等行业痛点, 难以适配现阶段复杂 Web 应用的安全检测需求。针对上述问题, 本文引入多智能 Agent 技术, 结合轻量化大语言模型, 设计并实现一套集中式多 Agent 全自动 Web 漏洞挖掘系统, 通过模块化分工协作与智能化自主学习, 提升漏洞检测的智能化水平与复杂场景适配能力。本文主要研究工作如下: 梳理国内外研究现状, 剖析技术痛点。本文系统调研现阶段国内外 Web 漏洞挖掘技术与智能安全 Agent 的研究现状, 深入分析静态检测、动态检测、模糊测试三类传统漏洞挖掘技术的底层原理与优缺点; 同时研究智能 Agent 与多智能体协同相关理论, 总结传统扫描工具相较于智能化 Agent 架构的核心短板, 明确本文课题研究意义与技术突破方向。完成多 Agent 系统总体方案设计。基于集中式多智能体架构, 设计四层分层系统架构, 将系统拆解为任务调度层、Agent 执行层、算法支撑层、数据持久层; 按照业务流程拆分出导航 Agent、探测 Agent、攻击 Agent、决策分析 Agent 四大功能模块, 明确各模块定位与运行逻辑; 同时制定串并行混合调度机制与标准化数据交互规范, 搭建完整的闭环漏洞检测体系。实现系统核心模块与算法优化。基于 Python 开发整套检测系统, 完成会话管理、漏洞特征库、记忆反馈三大公共基础模块开发; 优化动态页面交互式遍历算法, 解决传统爬虫无法适配动态 SPA 页面的难题; 依托轻量化大模型 Qwen-1.8B 实现智能载荷生成与变异, 结合多层级 WAF 绕过策略, 提升隐性漏洞挖掘能力; 构建多维综合漏洞判别模型, 摒弃单一响应码判定逻辑, 大幅降低漏洞误报率; 新增记忆反馈机制, 赋予 Agent 复盘迭代、自主优化的能力。开展多维度实验验证与结果分析。搭建标准化实验环境, 从功能性与性能两个维度完成全方位测试。功能性测试验证系统可全覆盖 SQL 注入、XSS、文件上传、权限越权、不安全反序列化五大类高危漏洞; 横向对比实验结果表明, 相较于 Xray、AWVS 传统扫描工具, 本文系统在复杂动态业务场景下漏报率、误报率显著降低, 检测效率更高, 能够有效弥补传统工具在动态页面与逻辑漏洞检测层面的不足。

### 6.2 进一步研究方向

受限于实验硬件条件与研究周期, 本文所设计的多 Agent 漏洞挖掘系统仍存在部分缺陷有待完善: 一是面对高强度 WAF、云防护等专业防火墙时, 部分高度加密混淆的攻击载荷易



被拦截，轻量化本地大模型复杂推理能力有限，对极端防护场景适配性不足；二是系统现阶段仅支持单机本地化部署，未开发分布式集群架构，并发扫描上限较低，无法满足大型企业大批量资产集群巡检需求；三是系统仅覆盖 OWASP Top10 主流漏洞，暂未支持代码审计、弱口令爆破、敏感信息泄露专项检测，功能覆盖面仍有提升空间。

## 参考文献

- [1] 吴世忠, 王嘉捷, 李斌. Web 应用漏洞动态检测技术研究综述 [J]. 通信学报, 2021, 42(05):1-18.
- [2] 陈性元, 张高萌, 杜学绘. 基于模糊测试的 Web 高危漏洞挖掘方法 [J]. 计算机应用研究, 2022, 39(03):815-820.
- [3] 周明, 刘群. 大语言模型技术与应用研究进展 [J]. 软件学报, 2023, 34(08):3201-3238.
- [4] 王鹤, 孙玉星. 多智能体协同决策机制研究及网络安全应用 [J]. 计算机科学, 2022, 49(07):291-298.
- [5] 李晨光. 面向动态 SPA 页面的爬虫优化与漏洞探测技术 [D]. 南京邮电大学, 2023.
- [6] 张宇航. 基于模糊测试的 Web 应用自动化漏洞扫描系统研究 [D]. 电子科技大学, 2022.
- [7] 刘嘉琦. 基于大语言模型的渗透测试载荷生成技术研究 [D]. 北京邮电大学, 2024.
- [8] 赵文强, 杨宏伟. Web 越权漏洞自动化检测技术研究 [J]. 计算机工程与设计, 2021, 42(11):3125-3131.
- [9] 黄杰, 陈勇. WAF 环境下 Web 攻击载荷混淆与绕过技术研究 [J]. 网络与信息安全学报, 2023, 9(02):156-168.
- [10] 马鑫, 王超. 分布式漏洞扫描系统任务调度优化算法 [J]. 小型微型计算机系统, 2022, 43(06):1256-1262.
- [11] 郭浩宇, 李丽. 基于多智能 Agent 的自动化红队演练框架 [J]. 计算机应用, 2024, 44(01):210-217.
- [12] 田宇轩. 基于记忆增强 Agent 的 Web 漏洞智能挖掘方法 [D]. 哈尔滨工业大学, 2025.
- [13] 林睿, 王泽贤. OWASP Top10 高危漏洞检测模型优化与实现 [J]. 信息技术, 2022, 46(08):78-84.
- [14] 孙博文, 周永彬. 轻量化大模型在 Web 安全检测中的应用研究 [J]. 计算机工程, 2024, 50(03):112-120.
- [15] 王浩宇, 陈建平. 动态网页爬虫异步元素识别与遍历算法 [J]. 计算机应用研究, 2023, 40(05):1458-1463.
- [16] Zhu Y, Kellermann A, Bowman D, et al. CVE-Bench: A Benchmark for AI Agents' Ability to Exploit Real-World Web Application Vulnerabilities[C]//ICML Workshop on AI for Cybersecurity. 2025:112-120.
- [17] Li X, Zhang H, Wang Y. APT-Agent: Automated Penetration Testing Framework Based on Large Language Model[J]. IEEE Access, 2026, 14:58921-58935.

- [18] Chen Z, Liu S. PentestAgent: Multi-Agent Collaborative Framework for Automatic Web Penetration Testing[J]. Computers Security, 2025, 139:103687.
- [19] Miller J, Brown K. Adaptive Multi-Agent Vulnerability Scanning for Dynamic Web Applications[C]//2024 IEEE International Conference on Cyber Security and Cloud Computing. IEEE, 2024:89-95.
- [20] Wang L, Feng R. Memory-Augmented LLM Agent for Fuzzing Test Payload Generation[J]. Applied Intelligence, 2026, 56(04):7891-7906.

## 附录 A 程序清单

### 第三章 QAM 系统 CMA 算法程序 (QAM programme 文件夹)

mainQAM\_MSE\_CMAvsCADAMA: QAM 系统, 画 MSE 曲线主函数

mainQAM\_SER\_CMAvsCADAMA: QAM 系统, 画 SER 曲线主函数

mainDQAM\_SER\_PhaseRotate: 差分 QAM 系统, 相位旋转下, 画 SER 曲线主函数

mainDQAM\_SER\_Doppler: 差分 QAM 系统, 多普勒频移下, 画 SER 曲线主函数

mainDQAM\_SER\_SNR: 差分 QAM 系统, 不同 SNR 下, 画 SER 曲线主函数

### 第四章 QPSK 系统 CMA 算法程序 (PSK programme 文件夹)

mainDPSK\_SER\_PhaseRotate: 差分 PSK 系统, 相位旋转下, 画 SER 曲线主函数

mainDPSK\_SER\_Doppler: 差分 PSK 系统, 多普勒频移下, 画 SER 曲线主函数

mainDPSK\_SER\_SNR: 差分 PSK 系统, 不同 SNR 下, 画 SER 曲线主函数

FunQPSK: QPSK 编码子函数

FunDeQPSK\_b: QPSK 解码子函数 (输出为比特)

### 第五章 CMA 频域均衡系统程序 (FDE programme 文件夹)

main\_CMAFDE: CMA 频域均衡主函数

FunCAZACSeGen: 产生 CAZAC 序列子函数

Fun8PSK: 8PSK 调制子函数

FunDe8PSK\_s: 8PSK 解调输出符号子函数

FunQPSK1: QPSK 调制幅度为 1 子函数

FunDeQPSK1\_s: QPSK 解调输出符号幅度为 1 子函数

FunSDCMA22f: 频域均衡 (2 2)SDCMA 算法子函数